

DataBase Security

1. ¿En qué consiste SQL Injection?

SQL Injection es un tipo de ataque donde la entrada de un usuario se diseña para aprovechar vulnerabilidades en la construcción dinámica de sentencias SQL. Al inyectar código en una consulta, el atacante puede, por ejemplo, obtener información no autorizada, borrar o modificar datos maliciosamente, o insertar datos que le concedan acceso indebido a la base de datos.

Fue descubierto alrededor de 1998 y hoy es considerado uno de los riesgos de seguridad más graves. Afecta la confidencialidad, integridad, disponibilidad, así como autenticación y autorización.

2. ¿En qué consiste Acces Control?

El Access Control consiste en asegurar que los datos y recursos de una base de datos solo sean accedidos de forma autorizada. Para esto, el administrador (DBA) define una matriz de control de acceso que indica qué usuarios, roles o aplicaciones pueden realizar operaciones como READ, INSERT, UPDATE o DELETE sobre cada objeto del sistema. Luego, esta configuración se implementa con un lenguaje de autorización que permite otorgar o revocar permisos.

3. ¿Comente el rol de Observabilidad en la seguridad de bases de datos?

La observabilidad en la seguridad de bases de datos consiste en monitorear y registrar todas las acciones y posibles violaciones mediante logs de seguridad y auditorías. Estos registros permiten detectar accesos sospechosos, identificar quién realizó cada operación, desde dónde y cuándo, e incluso registrar los cambios hechos en los datos. Así, ayuda a prevenir, investigar y responder ante incidentes de seguridad.

4. ¿Cómo se encripta información en una base de datos?

La encriptación en bases de datos consiste en almacenar y transmitir la información de forma cifrada para evitar que personas no autorizadas puedan leerla, incluso si logran acceder a los archivos del sistema o interceptar los datos.

- El proceso utiliza un sistema de cifrado compuesto por:
- Un algoritmo de encriptación, que transforma el texto original (plaintext) en texto cifrado (ciphertext).
- Una clave de encriptación, que determina cómo se aplica el algoritmo.
- Un algoritmo de desencriptación, que invierte el proceso para recuperar el texto original.
- Una clave de desencriptación, usada para descifrar la información.

Existen dos métodos principales:

- Cifrado simétrico, donde la misma clave se usa para cifrar y descifrar. Un ejemplo clásico es DES (Data Encryption Standard), que utiliza una clave de 56 bits para reorganizar y sustituir caracteres dentro de bloques de datos.

- Cifrado asimétrico o de clave pública, donde se emplean dos claves diferentes: una pública (para cifrar) y una privada (para descifrar). El método más conocido es RSA, basado en la dificultad de factorizar grandes números primos.